PDPL Data Privacy Summary

Riyadh Trust Bank — Synthetic Demo Document, not a real bank.

Document: PDPL Data Privacy Summary | Version: 1.0 | Department: Compliance | Effective: January 2026 | Review: July 2026

1. Purpose

This document summarises, in plain language, how Riyadh Trust Bank protects personal data under the Saudi Personal Data Protection Law (PDPL). Personal data is any information that identifies a person, such as their name, National ID number, phone number, address, account number or photograph. This summary is for staff training. It is not legal advice, and the bank's Data Protection Officer must be consulted for any question about the law.

2. Principles of Data Protection

The bank follows six principles. First, data is collected only for a clear purpose, such as opening an account or providing a loan, and is not used for another purpose without consent. Second, only the data that is needed is collected — no more. Third, data must be accurate and kept up to date. Fourth, data is kept only as long as needed, and for at least ten years after an account is closed where the KYC Policy requires it. Fifth, data is kept secure with access controls and encryption. Sixth, the bank is accountable and must be able to show that it follows these principles.

3. Customer Rights

Under the PDPL, every customer has the right to know what personal data the bank holds about them, to ask for a copy of it, to ask for it to be corrected if it is wrong, and to ask for it to be deleted when it is no longer needed and no law requires it to be kept. The customer also has the right to withdraw consent for marketing at any time. The bank must answer a customer data request within 30 days. The customer may complain to the Saudi Data and Artificial Intelligence Authority (SDAIA) if they are not satisfied with the bank's answer.

4. Consent and Sharing

The bank must get the customer's consent before collecting personal data, except where the law requires the collection, such as KYC identity checks. Personal data must not be shared with any other company without the customer's consent, except where the law requires it, for example to SAMA, to a court, or to the credit bureau SIMAH. Data must not be transferred outside Saudi Arabia without the approval of the Data Protection Officer and the controls required by the PDPL.

5. Data Breaches

A data breach is when personal data is lost, stolen or accessed by someone who should not see it. Any employee who discovers or suspects a data breach must report it to the Data Protection Officer and the IT security team immediately, and no later than 24 hours after discovery. The bank must assess the breach, contain it, and notify SDAIA and the affected customers if the breach is serious, within the time

required by the PDPL.

6. Employee Duties

Employees must only access customer data that they need for their own work. They must not look at the accounts of family members, friends or colleagues out of curiosity. They must lock their screens when they leave their desk, must not send customer data to a personal email address, and must not discuss customer information outside the bank. Every access to customer data is recorded in the audit log. Breaking these rules is gross misconduct and can lead to dismissal and to a fine under the PDPL.

Arabic Summary

ملخص عربي

يلخص هذا المستند حماية البيانات الشخصية بموجب نظام حماية البيانات الشخصية السعودي: تُجمع البيانات لغرض واضح فقط، وتُحفظ آمنة ومشفرة، ويحق للعميل الاطلاع على بياناته وتصحيحها وحذفها عند عدم الحاجة إليها، ويجب الرد على طلبه خلال 30 يوماً. يجب الإبلاغ عن أي خرق للبيانات خلال 24 ساعة، ويُمنع مشاركة البيانات دون موافقة.